DataGoblyn Third-Party Cybersecurity Risk and Compliance Assessment

Final Synthesis Presentation

Presented by: Meera Pillai

Date: June 2025

Introduction

Objective:

Assess and strengthen cybersecurity posture of DataGoblyn.

Strategic Goals Alignment:

- Maintain client trust through compliance.
- Ensure secure infrastructure for scalable AI.
- Position Synaptelligence as a trusted financial tech leader.

Assessment Process

1. Compliance Checklist – Evaluated 8 domains:

- Regulatory, Security Policies, Data Protection, Access Control, Third party risk management, Employee training, Monitoring and logging and Incident management

2. Risk Assessment – Identified:

- Key strengths & weaknesses
- Relevant risk scenarios
- Supplier overall security posture

3. Methods:

-Document review of policies, controls and procedures

-Checklist evaluation based on NIST CSF

-Gap analysis to assess compliance and risk.

Key Findings – Strengths

- Encryption for data at rest and in transit.

- Multi-Factor Authentication and defined access policies.

- Incident Response Plan in place.

Key Findings – Weaknesses

Secure Development: No SDLC integration or annually pen testing.

Access Management: No periodic access reviews.

Monitoring & Logging: Logs not actively monitored.

Compliance: No data minimization policy (GDPR/CCPA).

Vendor Oversight: No review of 3rd-party vendors.

Phishing: No simulation training or awareness program.

Risk Matrix

Likelihood	Impact	Risk Scenario
High	Critical	Data breach via third-party (Scenario 1)
High	High	Supply chain software attack (Scenario 7)
Medium	Critical	Ransomware attack on systems (Scenario 5)
Medium	High	Insider threat (Scenario 2)
Medium	High	Compliance failure with financial regulations (Scenario 4)

Risk Mitigation Plan

- Integrate Security into SDLC: Secure coding & review.
- Key Management: Formal encryption key lifecycle.
- Log Monitoring: SIEM tools (e.g., Splunk, FortiClient).
- Annual Pen Testing: Identify vulnerabilities.
- Access Reviews: Periodic audits, enforce least privilege.
- Staff Training: Phishing/social engineering awareness.

Continuous Monitoring Plan

- Quarterly Vendor Risk Reviews.

- SIEM (Security Information and Event Management)-Based Real-Time Alerting.

- Quarterly Phishing Simulations.

- Compliance Dashboard: Track encryption, MFA, patching, etc.

Conclusion

Risk Level:

High – due to lack of proactive measures.

DataGoblyn must address critical gaps to align with Synaptelligence's objectives.

Next Steps:

Enforce recommendations, monitor improvements, reassess in 6 months.